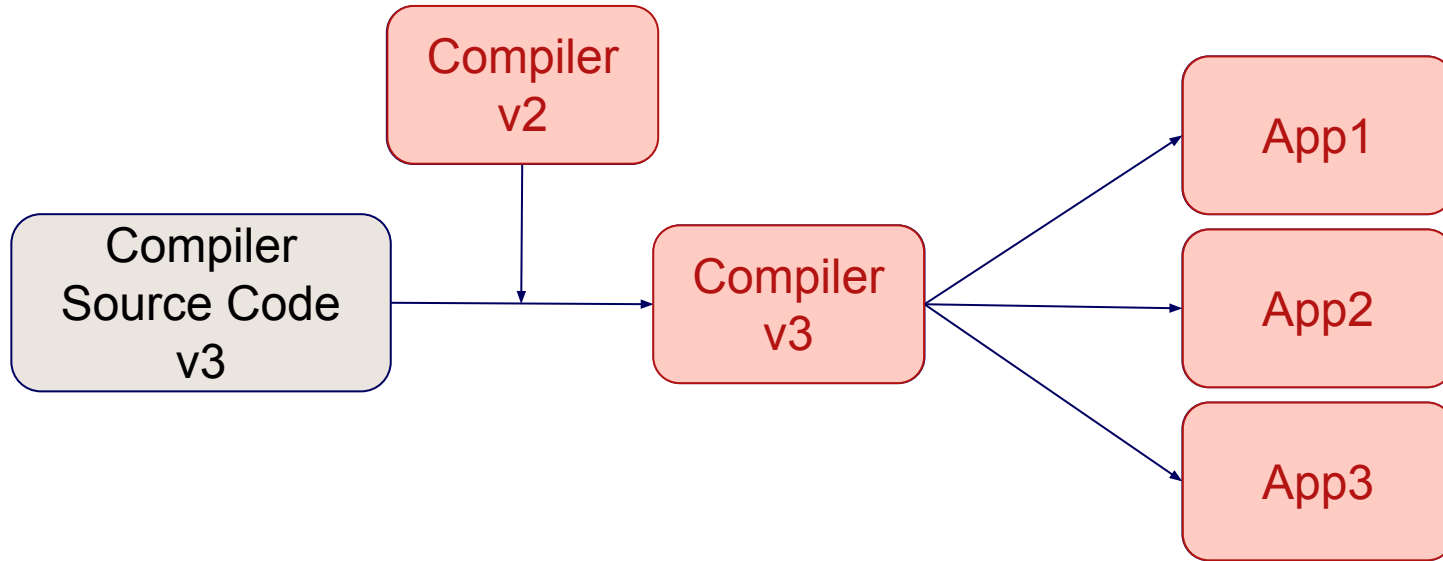




Trusting-trust attack against an entire Linux distribution through binary manipulation

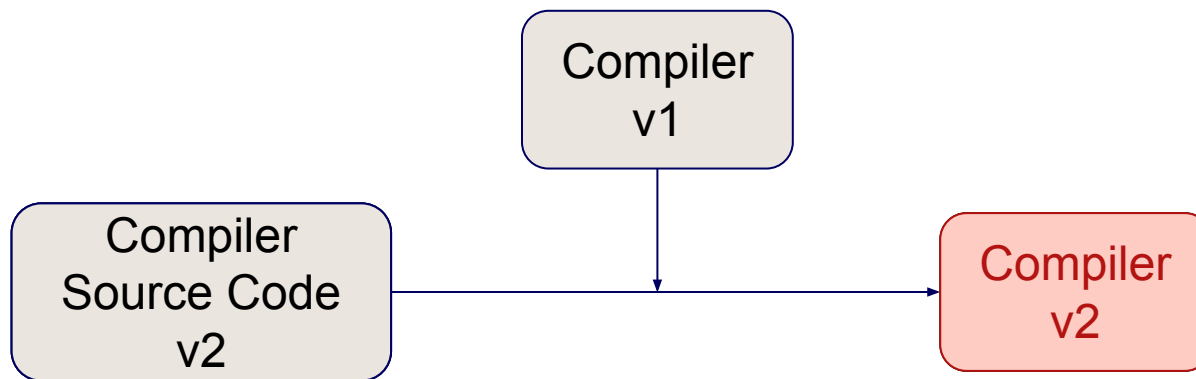
Julien Malka, Aman Sharma, Martin Monperrus, Stefano Zacchiroli, Théo Zimmermann

Trusting Trust Attack

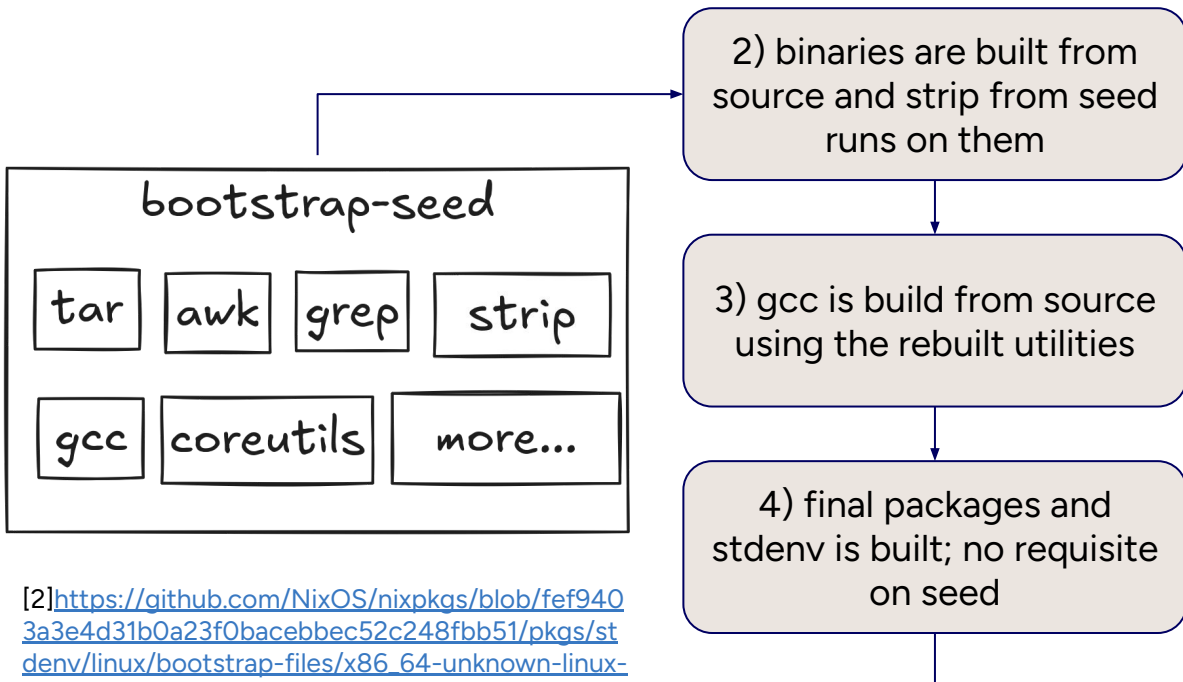


[1] K. Thompson, 'Reflections on trusting trust', Commun. ACM, vol. 27, no. 8, pp. 761–763, Aug. 1984

How to compromise compiler?



Nix Bootstrapping

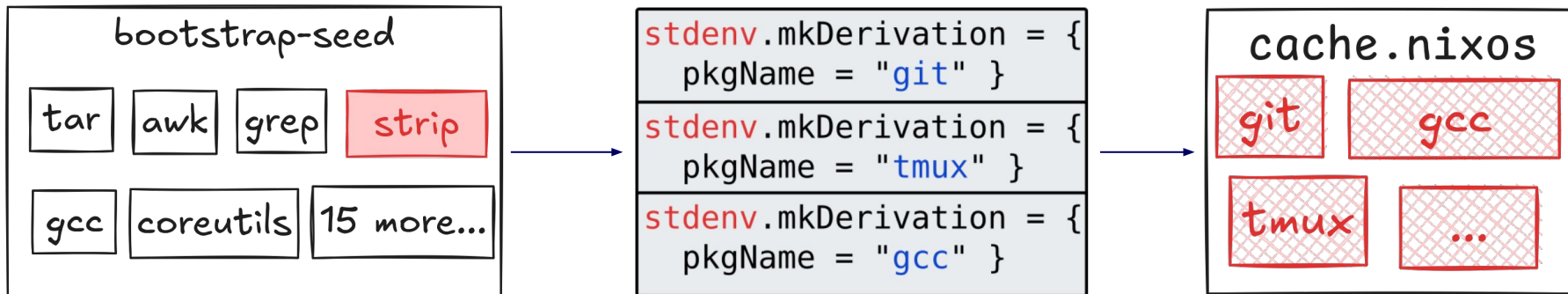


[2]https://github.com/NixOS/nixpkgs/blob/fef9403a3e4d31b0a23f0bacebbec52c248fbb51/pkg/stdenv/linux/bootstrap-files/x86_64-unknown-linux-gnu.nix

```
stdenv.mkDerivation {  
  pname = "git";  
  version = "2.45.2";  
  src = fetchurl {  
    url = "git-scm.com";  
    sha256 = "abcdef";  
  };  
};
```

But can we only do Trusting Trust attack with compilers?

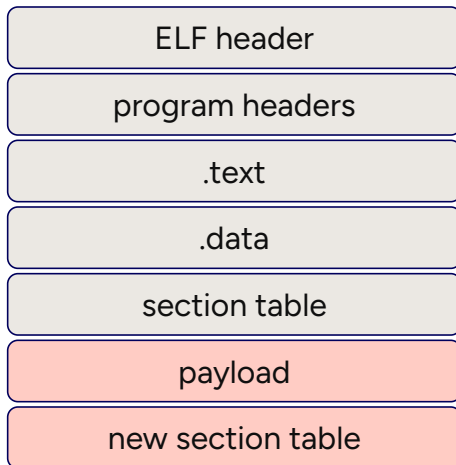
Attack



The attacker replaces one executable in the distribution's binary bootstrap seed.

Three ELF transformations

APPEND



REPURPOSE

NOTE offset virtaddr physaddr
filesz memsiz flags align

LOAD offset virtaddr physaddr
filesz memsiz flags align

REDIRECT

e_entry
0x401050 → payload

e_shoff
0x3400 → section table

The injector never rewrites existing code or data. Execution now begins in the payload, which returns to the host's original entry point.

Why strip?

C1 — Must be part of bootstrap seed

strip, patchelf, tar, xz,
make, awk, cp, install

C2 — Writes a finished binary

strip, patchelf, cp, install

C3 — Writes its own successor

strip, patchelf

Evaluation

3,790

of 3,799 user-invokable binaries in the trojaned graphical installer print the infection marker. The one exception is firefox 147.0.3, whose recipe passes `--disable-strip` and opts out of the phase entirely.

Nothing fails to build

The complete graphical ISO builds under the trojaned seed. Its runtime closure holds 3,790 (+ firefox + 8) executables and is 6.16 GB on disk.

Nothing fails its tests

The NixOS functional tests drive a full GNOME session and a from-scratch install. Every binary in that VM, gnome-shell and nautilus included, came from the trojaned strip. No test fails.

Replication Package: <https://github.com/chains-project/trusting-trust-attack-strip>

Language independence

ECOSYSTEM	EXAMPLE BINARY	SIZE	INFECTED
C / C++	git	56,313 KB	yes
Python	pydoc3.13	110 KB	yes
Rust	rsvg-convert	8,065 KB	yes
Go	captree	1,964 KB	yes
Lua	lua	328 KB	yes

▲ Trusting-Trust Attack against an Entire Linux Distribution (arxiv.org)

241 points by signa11 25 days ago | hide | past | favorite | 59 comments

[3]<https://news.ycombinator.com/item?id=49575515>

▲ Legend2440 25 days ago | parent | next [-]

Nothing about this uses AI in any way. I'm so tired of people injecting it into every conversation.

▲ fwlr 25 days ago | root | parent | next [-]

The attack doesn't use AI, but an AI could use the attack (and the researchers *definitely* used AI to write the paper!)

▲ Jach 1 day ago | next [-]

I'm glad they mention Wheeler's work briefly in section 7.2, since it provides a general counter to the trusting-trust attack that a lot of people seem to not know about. They dismiss it as not applying in this case, but I'm not really convinced by their argument. It's true if you only replace the compiler and run in the same environment then it won't help, but IIRC Wheeler's approach treats the environment itself as a parameter to diversify on. So not just the compiler, but also the host/OS, and even the hardware. Thus it's trivial to extend it to strip. Build binutils from source with your bad distro toolchain, fixup with your distro strip, call this build A. Then build binutils from source in a diverse environment, which includes fixup with a diverse stripper, call this B. Then do a rebuild (same diverse environment) but with B's toolchain and stripper, call this C, and compare C with A. Mismatch busts the attack.

Takeaway

1. The trusting-trust pattern extends beyond compilers.
2. The compromise propagates end to end through one NixOS bootstrap and persists in the final standard environment infecting 3,790 of 3,799 installer binaries.

I'M SPEAKING AT OPEN SOURCE SUMMIT EUROPE 2026

Maven-Lockfile

Locking Down the JVM Supply Chain for
Hermetic Builds



Aman Sharma

KTH ROYAL INSTITUTE OF TECHNOLOGY

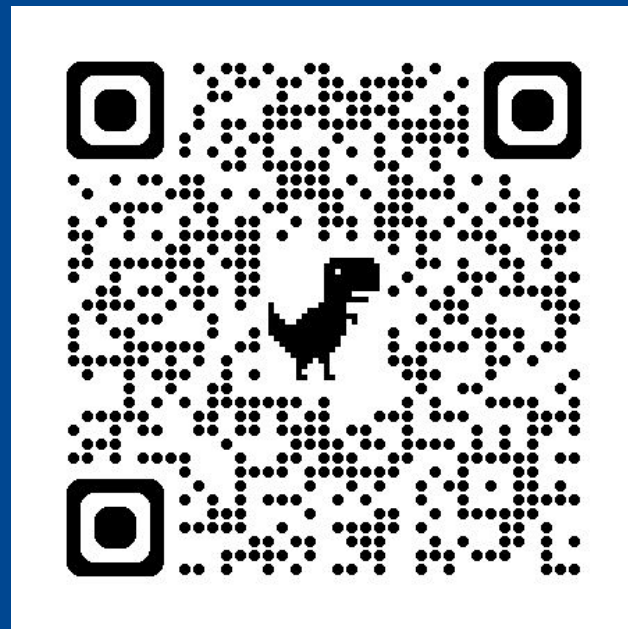
Bruno Pimentel

RED HAT

THURSDAY, OCTOBER 8, 2026 | 10:50 – 11:30 CEST | CLUB E (FLOOR 1)

Thank you

Aman Sharma
SCORED '26



arXiv Paper